

II.B.9 Audit's Role

An effective audit function provides independent, objective validation of controls and statements of assurance on the effectiveness of an entity's development, acquisition, and maintenance activities. Although auditors should not have any direct involvement in management decisions, they should raise objections if they believe the control environment is inadequate. Auditors may plan for their advisory capacity in development, acquisition, and maintenance activities by developing an understanding of the proposed system or changes. Auditors may require specialized knowledge of IT to advise on or review these activities. They should validate schedule adherence and management. Auditors should determine the effectiveness of controls in the entity's development, acquisition, and maintenance activities and recommend appropriate mitigation. They may communicate with developers regarding appropriate control standards and frameworks throughout IT projects.

Auditors do more than consult when reviewing controls in new or modified systems or components. In smaller or less complex entities, auditors typically assess an entity's development, acquisition, and maintenance activities during an "IT general controls"²¹ audit. Larger or more complex entities may have a dedicated IT audit function, which generally follows a risk-based approach to prioritize the review of numerous IT processes and controls. These entities may have separate audits to assess general processes, such as development, acquisition, or maintenance, or may review these activities as part of business line, project, or other technology audits. During each SDLC phase, auditors review the internal controls, testing, and audit trails included in systems and components.

Auditors may participate in an advisory capacity in IT projects and may perform pre- and post-implementation reviews. Post-implementation reviews should occur shortly after implementing the new or revised system or components. These reviews help validate that the system or component operates as expected and provide financial statement users with relevant information in ways that justify the cost of providing it.

In larger or more complex entities with numerous IT systems and components, formal quality management or change management groups may have primary responsibility for post-implementation reviews. In such cases, auditors may choose not to perform a separate review; however, they may participate in validating minimum test criteria and evaluating the results of reviews.

Auditors' validation activities regarding IT projects or change management may include reviews for the following:

- Project or changes were authorized.
- Project or changes were subjected to a risk-impact assessment.
- Project or changes were handled effectively and formally documented, especially when it was an emergency change.

²¹ While "IT general controls" is a typical name for all-encompassing IT audits, entities may use various names for these reviews.

- Project or changes were prioritized among all other IT projects or changes in a manner that is effective for the entity.
- Project or changes were tracked by a formal process.

For more information, refer to the *FFIEC IT Handbook's* “[Audit](#)” booklet.

III RISK MANAGEMENT OF DEVELOPMENT, ACQUISITION, AND MAINTENANCE

Action Summary

Management should implement continual risk management processes within the entity's development, acquisition, and maintenance activities to identify, measure, monitor, and control reasonably foreseeable internal and external risks and threats, including those that could result in unauthorized disclosure, misuse, alteration, or destruction of customer information or customer information systems.

Examiners should review the following:

- Policies, standards, and procedures for identifying, measuring, mitigating, monitoring, and reporting risks related to development, acquisition, and maintenance activities.
- Documented processes and metrics used to measure the level of risk.
- Detailed documentation of processes used to review, accept, and document risks that management cannot mitigate or transfer.
- Documentation of risk assessment processes to identify key risks at the onset of IT projects and throughout their life cycles.
- Risk assessments that highlight internal and external risks related to development, acquisition, and maintenance activities.
- Documentation of ongoing processes and reports to monitor and communicate risk, including emerging risks related to development, acquisition, and maintenance activities.
- Reports to stakeholders that are timely, accurate, and include clear, relevant metrics.

Management should identify, measure, monitor, and control reasonably foreseeable internal and external risks and threats, including those that could result in unauthorized disclosure, misuse, alteration, or destruction of customer information or customer information systems.²² While the requirement is relative to risks to sensitive customer information, it is a prudent practice relative to any sensitive information type. Additionally, management should consider risks that could result in a severe disruption or material compromise to critical service delivery. It is also important to consider known risks related to developed or acquired products and systems,²³ and

²² Refer to 15 USC 6801 and 6805(b), "[Financial Services Modernization Act of 1999](#)" ([Gramm–Leach–Bliley Act or GLBA](#)), further implemented by FFIEC members as follows: FDIC: 12 CFR 364, appendix B, "[Interagency Guidelines Establishing Information Security Standards](#)"; FRB: Regulation H, 12 CFR 208, appendix D-2, "[Interagency Guidelines Establishing Information Security Standards](#)"; and Regulation Y, 12 CFR 225, appendix F, "[Interagency Guidelines Establishing Information Security Standards](#)"; NCUA: 12 CFR 748, appendix A, "[Guidelines for Safeguarding Member Information](#)"; and OCC: 12 CFR 30, appendix B, "[Interagency Guidelines Establishing Information Security Standards](#)." Additionally, refer to Federal Trade Commission (FTC) 16 CFR 314, "[Standards for Safeguarding Customer Information](#)."

²³ Developed or acquired products and services may include hardware (e.g., servers, laptops), software (e.g., application programming interfaces), or services (e.g., banking-as-a-service).

any known potential misuses. IT risk management activities should include policies, standards, and procedures for identifying, measuring, mitigating, monitoring, and reporting risks related to development, acquisition, and maintenance activities. Additionally, management should consider using threat models to assess security policies, standards, and procedures. While there are many widely used threat modeling methodologies, it is important for entity personnel to consider implementing a model commensurate with the threats in the entity's overall environment.

Risk management activities include identification of risks associated with development, acquisition, maintenance, and associated IT projects, including the risks associated with not initiating a project.²⁴ Examples of risk management activities to consider include the following:

- Measuring each activity's level of risk.
- Mitigating risks to an acceptable, board-approved level of residual risk.
- Monitoring risks related to development, acquisition, and maintenance activities.
- Reporting updates to senior management and the board, as necessary.

At times, management may choose to transfer some of the risk, such as by purchasing insurance (e.g., errors and omissions or cyber) to address the potential for unknown errors in source code. When management cannot mitigate or transfer risk, there should be a process to review, accept, and document the risk and its acceptance by the board. For an acquisition, management and the board may decline to move forward if the risk level exceeds the board's risk appetite (e.g., purchase of a product that uses an amount of open-source code above approved levels). Management and the board should regularly review and approve risk acceptance decisions consistent with the entity's governance structure. For more information about risk management, refer to the *FFIEC IT Handbook's* "[Management](#)" booklet.

III.A Risk Identification

Risk identification involves identifying and documenting risks that may affect development, acquisition, and maintenance activities. Effective risk identification is a continuous process that includes iterative reassessment of risks. Identifying key risks related to development, acquisition, and maintenance activities gives management opportunities to implement appropriate controls and mitigate risks. Identifying key risks at the onset of an IT project allows for early assessment of risks, risk effects, and risk mitigation options. For example, a code review helps developers find errors before migrating code between the test and the production environments. Ideally, risk identification and assessments involve stakeholders with business process knowledge who may be affected by the development, acquisition, or maintenance activities or the related IT projects. As always, information security concerns should also be considered.

Risk identification highlights internal and external risks related to development, acquisition, and maintenance activities. Examples of internal risks include insider threats (e.g., trusted employees who use authorized access in an unauthorized manner for personal gain, entity harm, or errors and omissions) and scheduling difficulties (e.g., loss of knowledgeable personnel or

²⁴ There is a strong relationship between the phases in the SDLC, the SCRUM life cycle (both discussed in this booklet), and the third-party risk management life cycle, referenced in the [Interagency Guidance on Third-Party Relationships: Risk Management](#).

unavailability of skilled personnel). Examples of external risks include those arising from third-party relationships, industry threats and changes (e.g., new products or services, regulatory changes, or new cyber threats), and natural disasters. Additionally, financial technology (fintech)²⁵ firms and other third-party relationships may not be subject to the same regulatory requirements as the entity. Management is responsible for holding the third party accountable to the entity's standards (e.g., compliance with regulations and adherence to security and resilience standards) and the board's risk appetite.

III.B Risk Measurement

Management should implement effective standards to measure risk in the entity's development, acquisition, and maintenance activities. Risk measurement should be an ongoing process and commensurate with the size and complexity of an entity's activities. As the complexity of an entity's activities and processes increases, management may benefit from using automated tools to help measure risk. Effective risk measurement processes include management setting and monitoring objective standards for performance. Examples of risk measurement related to development, acquisition, and maintenance include the following:

- Comparisons of estimated versus actual completion dates for IT project deliverables.
- Number of open issues related to projects and the length of time issues remain open.
- Percentage of occasions when management needed to back code out of production.
- Cost overruns greater than the entity's established limits.
- Service levels below those defined in contracts and agreements.
- Number of unapplied patches or patches applied beyond the policy time frames.
- Policy exceptions.

III.C Risk Monitoring and Reporting

Effective management monitors and reports risks related to development, acquisition, and maintenance activities. Examples of risks monitored by management include project management (e.g., milestone date shifts, negative test results, and major requirements changes), cybersecurity, supply chain, and emerging technology. Reports of these risks should be timely and accurate; include clear, relevant metrics (e.g., trends related to the number of open issues or code back-outs); and note deviations from policies, standards, and procedures. Reports should be distributed to appropriate stakeholders, including the board when necessary. Management should communicate technical aspects that are easily understood (e.g., explaining acronyms or technical jargon) when reporting to the entity's board and relate the IT issues to the entity's business concerns. Effective monitoring and reporting inform management about problems and performance issues in a timely manner, so that management can minimize the potential for an increase in the levels of risk associated with identified issues. Monitoring and reporting should enable all stakeholders to understand the risks and agree with the proposed courses of action.

²⁵ For purposes of this booklet, "fintech" refers to using technology in novel ways to provide financial services.

III.D Controlling or Mitigating Risk

Risk mitigation relies on identification and monitoring of risk in conjunction with the board's risk appetite. These limits should assist in limiting exposure to the various risks associated with the entity's IT-related activities. Implementation of effective operational controls to address these risks are described throughout this booklet. One example of risk mitigation is implementing code reviews during development to detect and correct errors earlier in the development process that might cause the system or component to fail. Effective management adopts repeatable control processes to ensure that risks are consistently addressed across the entity over time.

IV COMMON DEVELOPMENT, ACQUISITION, AND MAINTENANCE RISK TOPICS

Action Summary

Management should implement effective risk mitigation throughout development, acquisition, and maintenance activities regardless of the phase of the project in the life cycle and agnostic as to the type of technology. Specific risks and controls should be considered depending on management's chosen solution.

Examiners should review the following:

- Systems, components, and services, including related contracts and licenses, throughout the supply chain for appropriate risk identification and mitigation.
- Security controls (e.g., secure coding requirements and baseline configuration use) used to harden systems and components.
- Inventory of all systems and components (e.g., open-source, proprietary, application programming interfaces [API], and container images and registries), including related licenses, and data as part of IT asset management (ITAM).
- Access, authentication, and authorization controls for systems, components, data, and related documentation throughout the supply chain to ensure appropriate security.
- Segregation of duties in development, acquisition, and maintenance activities.
- Process of selecting and implementing methodologies to enable effective management and control of development, acquisition, or maintenance projects and alignment with entity objectives.
- Operating parameters (e.g., timing, speed, throughput, and data validation) for systems and components to determine performance.
- Activity logs related to systems, components, and data to identify operating risks.
- Monitoring processes of development and maintenance activity for identification of anomalies and unauthorized access or modification to systems, components, and data.
- Reporting processes for decision-making and measuring the level of project success.
- Training on development, acquisition, and maintenance concepts (e.g., methodologies); effectiveness of training; and capability of personnel to implement concepts learned.
- Documentation of internally developed systems and components and externally procured products and services to effectively operate and maintain the systems and components.
- Evaluation process (e.g., post-implementation review, stakeholder interview, problem documentation and resolution, cost-benefit analysis, and reports to senior management) for development, acquisition, and maintenance projects.

IT systems are designed, built, and implemented to achieve strategic goals and business objectives. While there are risks specific to each of the development, acquisition, and maintenance activities, certain risk considerations are common to all three. Common

development, acquisition, and maintenance risk topics are discussed in the following subsections of this booklet:

- “Open-Source”
- “Commercial-off-the-Shelf”
- “Licenses, Agreements, and Copyright Protection”
- “Secure Development”
- “Data”
- “Secure Operating Environments”
- “Microservices”
- “Containers”
- “Application Programming Interfaces”
- “Quality Management”
- “Documentation Standards”
- “Post-Implementation Review”
- “IT Project Management”
- “System Development Life Cycle”
- “Supply Chain Considerations”

IV.A Open-Source

Open-source software is software released under a license that allows the software and its source code to be accessed, used, modified, and shared by anyone.²⁶ Effective management identifies and mitigates risks related to the use of open-source components (e.g., open-source software components and hardware components). For example, components may be based on poorly written code, or the developer may not have properly addressed security concerns. Open-source vulnerabilities may be more common depending on the underlying code’s quality because the overall review process for open-source is less transparent and more difficult to validate. If the original developer makes updates, they may not be pushed to the entity. In that case, effective management would request updates from the original open-source developer to address vulnerabilities and manually deploy updates. Alternatively, when the original developer does not make updates to open-source systems and components, effective management may engage in-house or third-party software development personnel to update the software.

The Open Worldwide Application Security Project (OWASP) recommends the following component analysis²⁷ strategies to reduce risks associated with the use of open-source components:²⁸

²⁶ For more information, refer to NIST Directive S 6106.01, “[Open Source Code](#).”

²⁷ OWASP defines “component analysis” as “the process of identifying potential areas of risk from the use of third-party and open-source software and hardware components.”

²⁸ For more information, refer to OWASP, [Component Analysis](#).

- Evaluating the type of framework and libraries to reduce architectural changes, regressions (or defects), and code rewrites.
- Identifying and analyzing the purpose of each component to reveal the existence of components with duplicate or similar functionality.
- Evaluating the number of third-party and open-source components in a project because the higher the number, the more difficult it is for development teams to maintain large sets of components over time.
- Using private central repositories²⁹ or public repositories' code-signing and verification tools to minimize risk of threats³⁰ related to public repositories.
- Identifying a component's provenance³¹ to help ensure knowledge of authorship of software components, manufacturers, suppliers, software repositories, and country of origin.
- Maintaining accurate formulation³² and pedigree³³ information for source code that is readily available, modifiable, and redistributable.
- Identifying the license for a given component and whether it allows certain types of usage, contains distribution requirements or limitations, or requires specific actions if the component is modified.
- Aggregating the risk of all direct, transitive, runtime, and environmental dependencies providing a holistic view of inherited risk.³⁴

²⁹ A "[repository](#)" is defined as "a place, room, or container where something is deposited or stored." For purposes of IT, repositories may store requirements, policies, processes, data, software libraries, projects, configurations, performance goals, and applications, with the potential of supporting both software development and operations management.

³⁰ Some of the threats against public repositories include typosquatting (i.e., naming a component to take advantage of common misspelling); organization/group abuse (i.e., pretending to be a public person or entity and abusing the perceived trust); malware through transfer (i.e., leveraging weak or absent code-signing requirements to spread malware through the transfer of an open-source project from one maintainer to another); and cross-build injection (i.e., abusing dependency resolution schemes and weak infrastructure controls to inject malicious components in place of safe ones).

³¹ For purposes of this discussion, the identification of a component's provenance refers to the chronology of the origin, development, ownership, location, and changes to a system or system component and associated data. It can include personnel and processes used to interact with or make modifications to the system, component, or associated data.

³² OWASP describes "[formulation](#)" as "how components were built...and a comprehensive list of parallel and sequential steps that were taken to build, test, and deliver a component."

³³ NIST Glossary defines "[pedigree](#)" as "the validation of the composition and provenance of technologies, products, and services is referred to as the pedigree. For microelectronics, this includes material composition of components. For software this includes the composition of open source and proprietary code, including the version of the component at a given point in time. Pedigrees increase the assurance that the claims suppliers assert about the internal composition and provenance of the products, services, and technologies they provide are valid."

³⁴ Inherited risks are derived from an application's transitive dependency (i.e., when an application or component has a direct dependency on another component and that component then has a dependency on another component) or direct dependency on every component. Transitive dependencies have their own risk that is inherited by every component and application that relies on them. Refer to OWASP, [Component Analysis](#).

- Evaluating the health of an open-source project through quality controls and metrics (e.g., frequency of code changes and patches), community engagement (e.g., user base and involvement), and vulnerability analysis.
- Including external services (such as those relied on for functionality) in the overall inventory of components.

During software evaluation, a review of the open-source developer's formal documentation helps management determine potential software maintenance risks after software selection. Open-source documentation may be less comprehensive when compared with documentation for proprietary systems and components. Effective management proactively maintains updated application and user documentation, especially when code changes are made.

For more information, refer to the *FFIEC IT Handbook's* "[Information Security](#)" and "[Architecture, Infrastructure, and Operations](#)" booklets.

IV.B Commercial-off-the-Shelf

Commercial off-the-shelf (COTS) systems are systems, components, or solutions that are ready-made and available for sale, lease, or license to the general public. COTS is also referred to as off-the-shelf. Entities typically use COTS for operating systems (OS), applications, network infrastructure, servers, desktops, laptops, and mobile devices. Entities often choose to use COTS because it generally is less costly than developing systems and components in-house and requires fewer resources to maintain. COTS solutions generally provide a default set functionality. For example, a default installation of a server OS may include mail, web, and file-sharing services whether or not the solution requires those functions. This is because COTS providers may be developing their products to serve a wide variety of customers, not just those in the financial industry. Therefore, unnecessary services may be present in COTS and represent potential security weaknesses (e.g., unnecessary services creating a wider attack surface), which should be mitigated (e.g., turned off or patched). Protection against those risks begins when the systems or components are constructed and installed through a process referred to as "hardening." Management should consult third-party providers and vendors regarding recommended security controls to harden the COTS solution. Hardening can involve employing recommendations in a documented installation procedure and generally includes the following:

- Changing default passwords.
- Installing the most secure, up-to-date versions of applications.
- Configuring security settings as appropriate.
- Enabling logging.
- Configuring backups to increase resilience.

A COTS solution may be integrated with existing systems and components to provide additional or enhanced business services to internal and external customers. Management should mitigate any risks related to integration (e.g., lack of interoperability or integration between systems and components). If modifications are made, the process to develop and implement them may be time-consuming and challenging. These modifications may result in additional configuration changes for COTS, or interface changes between COTS and other systems and components (e.g.,